

Acme Corp

Data Protection & Encryption Policy

Version 2.4 | Effective: February 1, 2025

Classification: Internal / Confidential

This document is the property of Acme Corp and is intended for internal use only. Unauthorized distribution, reproduction, or disclosure is strictly prohibited. This policy has been approved by the Chief Information Security Officer (CISO) and is effective as of the date indicated above.

1 Purpose and Scope

This policy defines the requirements for protecting sensitive data including cardholder data (CHD), personally identifiable information (PII), and other confidential business information throughout its lifecycle. It covers data classification, encryption standards, key management, data retention, and secure disposal procedures. This policy applies to all systems that store, process, or transmit protected data within Acme Corp environments.

2 Data Classification

All data must be classified according to its sensitivity level. The classification levels are: Public (information approved for unrestricted distribution), Internal (information for internal use that could cause minor harm if disclosed), Confidential (information whose disclosure could cause significant harm including PII and business-sensitive data), and Restricted (the highest sensitivity level including cardholder data, authentication credentials, and cryptographic keys). Data owners are responsible for assigning the appropriate classification level.

3 Encryption of Data at Rest

3.1 Encryption Standards

All cardholder data stored in databases, file systems, backup media, and portable storage devices must be encrypted using AES-256 or equivalent cryptographic algorithms approved by NIST. Full-disk encryption must be enabled on all laptops and workstations that may contain sensitive data. Database-level encryption using Transparent Data Encryption (TDE) is required for all production databases containing cardholder data.

3.2 Primary Account Number (PAN) Protection

The full Primary Account Number must be rendered unreadable anywhere it is stored, whether in databases, log files, backup media, or removable media. Acceptable methods include: one-way cryptographic hashes based on strong cryptography (SHA-256 minimum), truncation (showing no more than the first six and last four digits), index tokens and pads with securely stored pads, or strong cryptography with associated key-management processes. PAN must not appear in plaintext in log files, debugging output, or error messages.

4 Encryption of Data in Transit

All sensitive data transmitted over public networks must be encrypted using TLS 1.2 or higher. SSL and early TLS protocols (TLS 1.0, TLS 1.1) are explicitly prohibited. Wireless networks transmitting cardholder data must use industry best-practice encryption (WPA3 or WPA2 with AES). Internal network transmissions of cardholder data between system components must also be encrypted. Email communications containing sensitive data must use S/MIME or PGP encryption.

5 Cryptographic Key Management

5.1 Key Generation and Storage

Cryptographic keys must be generated using approved random number generators within FIPS 140-2 validated hardware security modules (HSMs) or equivalent. Keys must be stored in a secure key management system separate from the data they protect. Key-encrypting keys must be at least as strong as the data-encrypting keys they protect. Split knowledge and dual control procedures must be used for all manual key-management operations.

5.2 Key Rotation and Retirement

Data-encrypting keys must be rotated at least annually or whenever there is a suspicion of compromise. Retired keys must not be used for new encryption operations but may be retained in a read-only state for decryption of archived data. Key destruction must use approved methods such as zeroization of HSM key slots or cryptographic erasure. All key lifecycle events must be logged and auditable. A key custodian must be formally designated and must acknowledge their responsibilities in writing.

6 Data Retention and Secure Disposal

Account data storage must be kept to a minimum. Data retention policies must define the specific retention period for each data type and the business justification for retaining it. Cardholder data that exceeds the defined retention period must be securely deleted on a quarterly basis. Secure deletion methods include: cryptographic erasure, degaussing of magnetic media, physical destruction (cross-cut shredding for paper, incineration for optical media). Sensitive authentication data (SAD) including the full track data, card verification codes (CVV/CVC), and PINs must never be stored after authorization, even in encrypted form.